Xác thực liên tục thích ứng dựa trên nhịp gõ phím

Phát hiện tiếp quản phiên sau khi đã qua MFA

Giảng viên hướng dẫn:
PGS.TS. Đặng Trần Khánh
TS. Phạm Thị Bạch Huệ
ThS. Lương Vĩ Minh

Nhóm 02 (2026-10-20)
25C12011 - Nguyễn Bảo Trâm
25C11012 - Võ Công Minh
25C12016 - Trần Huy Vũ
25C12031 - Dương Tấn Huỳnh Phong

Mục Lục

1. Bối cảnh và bài toán
2. Phương pháp và kiến trúc
3. Thực nghiệm và kết quả
4. Demo
5. Giới hạn và kết luận

01

Bối cảnh và bài toán

Khoảng hở sau MFA

Khoảng hở sau MFA

MFA (Multi-Factor Authentication, xác thực đa yếu tố) chỉ kiểm tra lúc đăng nhập

Phiên đã xác thực: máy chủ chỉ kiểm tra bí mật phiên
(cookie hoặc token) ở mỗi yêu cầu

Khoảng hở
cần rút ngắn



09:00
Người dùng đăng nhập và qua MFA

13:20
Kẻ tấn công chiếm phiên đang mở

13:21
Hệ thống cần phát hiện và yêu cầu xác thực lại

Minh họa, không theo tỉ lệ thời gian

Cookie phiên

Mã định danh ngẫu nhiên, không chứa nhịp gõ.

Trình duyệt → session_id → Máy chủ: hợp lệ ✓
(không biết ai gõ)

Khoảng hở sau MFA

MFA (Multi-Factor Authentication, xác thực đa yếu tố) chỉ kiểm tra lúc đăng nhập

Phiên đã xác thực: máy chủ chỉ kiểm tra bí mật phiên
(cookie hoặc token) ở mỗi yêu cầu

Khoảng hở
cần rút ngắn



09:00
Người dùng đăng nhập và qua MFA

13:20
Kẻ tấn công chiếm phiên đang mở

13:21
Hệ thống cần phát hiện và yêu cầu xác thực lại

Minh họa, không theo tỉ lệ thời gian

Cookie phiên

Mã định danh ngẫu nhiên, không chứa nhịp gõ.

Trình duyệt → session_id → Máy chủ: hợp lệ ✓
(không biết ai gõ)

NIST SP 800-63B-4

Giám sát phiên: **tùy chọn**.
Xác thực lại định kỳ: **bắt buộc**.

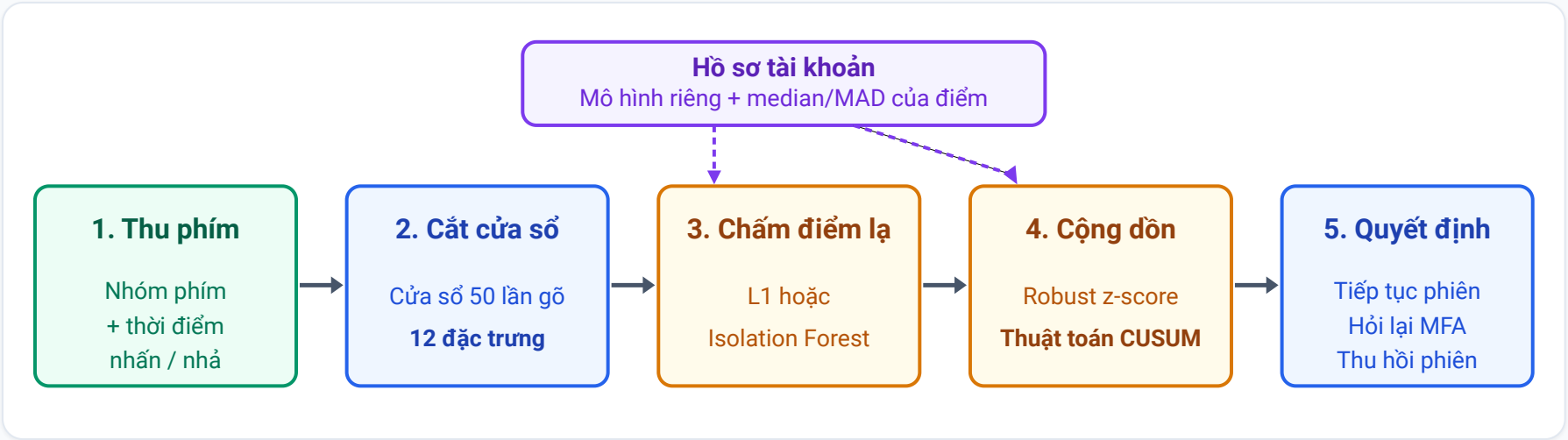
Khi nghi vấn

Hỏi lại MFA: khi mức rủi ro vừa.
Thu hồi phiên: khi mức rủi ro cao.

Xác thực liên tục

Xác thực liên tục

Định nghĩa và ứng dụng thực tế



Đánh giá liên tục
tín hiệu trong phiên → tiếp tục / hỏi MFA / thu hồi

Xác minh 1:1:
"đúng chủ không?", không phải "đây là ai"

TypingDNA ActiveLock:
theo dõi cách gõ, khóa máy hoặc cảnh báo

Vì sao chọn nhịp gõ

Vì sao chọn nhịp gõ

So sánh với các biện pháp kiểm soát phiên

Biện pháp	Ưu điểm	Giới hạn
Timeout phiên	Giới hạn thời gian phiên	Kẻ lạ tiếp tục thao tác vẫn giữ phiên
Xác thực lại định kỳ	Điểm kiểm tra rõ	Gây gián đoạn; còn khoảng hở giữa 2 lần
IP, thiết bị	Thêm tín hiệu rủi ro	Dùng máy đang mở: tín hiệu không đổi
Nhịp gõ phím	**Thu thụ động bằng bàn phím sẵn có**	**Cần đủ phím; không gõ thì không có chứng cứ**

Mỗi người gõ một kiểu

(136 triệu lần nhấn phím của 168.000 người, Dhakal 2018).

Ưu điểm lớn nhất:

Thu thụ động, không cần thêm phần cứng, có bằng chứng ngay khi thao tác gõ.

Nhược điểm lớn nhất:

Không gõ thì không có bằng chứng → là **lớp bổ sung**, không thay thế MFA.

Nghiên cứu liên quan

Nghiên cứu liên quan

Phân loại, đặc trưng và đánh giá

2005 Gunetti • **2009** Killourhy • **2012** Bours • **2020** Kiyani • **2021–24** TypeNet, TypeFormer • **2025** KVC-onGoing

Hướng và đặc trưng	Đại diện	Đánh giá với tiếp quản phiên
Thống kê/khoảng cách	Gunetti 2005; Killourhy 2009	Có quy trình so sánh; chưa có trục TTD

Nghiên cứu liên quan

Phân loại, đặc trưng và đánh giá

2005 Gunetti • **2009** Killourhy • **2012** Bours • **2020** Kiyani • **2021–24** TypeNet, TypeFormer • **2025** KVC-onGoing

Hướng và đặc trưng	Đại diện	Đánh giá với tiếp quản phiên
Thống kê/khoảng cách	Gunetti 2005; Killourhy 2009	Có quy trình so sánh; chưa có trục TTD
Xác thực liên tục	Bours 2012; Kiyani 2020	**Gần bài toán nhất; nhóm thêm TTD, MFA/giờ**

Nghiên cứu liên quan

Phân loại, đặc trưng và đánh giá

2005 Gunetti • **2009** Killourhy • **2012** Bours • **2020** Kiyani • **2021–24** TypeNet, TypeFormer • **2025** KVC-onGoing

Hướng và đặc trưng	Đại diện	Đánh giá với tiếp quản phiên
Thống kê/khoảng cách	Gunetti 2005; Killourhy 2009	Có quy trình so sánh; chưa có trục TTD
Xác thực liên tục	Bours 2012; Kiyani 2020	**Gần bài toán nhất; nhóm thêm TTD, MFA/giờ**
Học sâu	TypeNet 2021; TypeFormer 2024	Minh họa; khác miền; chưa tái hiện

Nghiên cứu liên quan

Phân loại, đặc trưng và đánh giá

2005 Gunetti • **2009** Killourhy • **2012** Bours • **2020** Kiyani • **2021–24** TypeNet, TypeFormer • **2025** KVC-onGoing

Hướng và đặc trưng	Đại diện	Đánh giá với tiếp quản phiên
Thống kê/khoảng cách	Gunetti 2005; Killourhy 2009	Có quy trình so sánh; chưa có trục TTD
Xác thực liên tục	Bours 2012; Kiyani 2020	**Gần bài toán nhất; nhóm thêm TTD, MFA/giờ**
Học sâu	TypeNet 2021; TypeFormer 2024	Minh họa; khác miền; chưa tái hiện
Benchmark	KVC-onGoing 2025 (hơn 185.000 người)	Chuẩn xác minh; không đo đổi người giữa phiên

Khoảng trống: FAR/FRR/EER không cho biết cần bao nhiêu phím → thêm **TTD** và **MFA/giờ**.

Mô hình đe dọa

Mô hình đe dọa

Giả định kẻ tấn công: Đã có phiên hợp lệ (ngồi vào máy mở hoặc có cookie); không sửa được hồ sơ máy chủ, không bẻ được TLS.

TÀI SẢN CẦN BẢO VỆ

Phiên đã đăng nhập: Không để kẻ lạ dùng quyền hạn của chủ.

Trải nghiệm chủ thật: Không hỏi MFA quá nhiều, không thu hồi oan.

Hồ sơ nhịp gõ: Tránh bị chèn dữ liệu xấu làm sai lệch nhận dạng.

Riêng tư người dùng: Không lưu ký tự, chỉ ghi nhận thời điểm.

KỊCH BẢN TẤN CÔNG

A1	Người lạ dùng máy đang mở, gõ theo thói quen của mình.	Đã đo
A2	Biết nội dung cần gõ, nhưng không biết nhịp gõ của chủ.	Chưa đo
A3	Luyện bắt chước nhịp gõ của chủ thật.	Chưa đo
A4	Ghi lại gói dữ liệu nhịp gõ rồi gửi phát lại (replay).	Chưa đo

Mô hình đe dọa

Giả định kẻ tấn công: Đã có phiên hợp lệ (ngồi vào máy mở hoặc có cookie); không sửa được hồ sơ máy chủ, không bẻ được TLS.

TÀI SẢN CẦN BẢO VỆ

Phiên đã đăng nhập: Không để kẻ lạ dùng quyền hạn của chủ.

Trải nghiệm chủ thật: Không hỏi MFA quá nhiều, không thu hồi oan.

Hồ sơ nhịp gõ: Tránh bị chèn dữ liệu xấu làm sai lệch nhận dạng.

Riêng tư người dùng: Không lưu ký tự, chỉ ghi nhận thời điểm.

KỊCH BẢN TẤN CÔNG

A1	Người lạ dùng máy đang mở, gõ theo thói quen của mình.	Đã đo
A2	Biết nội dung cần gõ, nhưng không biết nhịp gõ của chủ.	Chưa đo
A3	Luyện bắt chước nhịp gõ của chủ thật.	Chưa đo
A4	Ghi lại gói dữ liệu nhịp gõ rồi gửi phát lại (replay).	Chưa đo

Mô hình đe dọa

Giả định kẻ tấn công: Đã có phiên hợp lệ (ngồi vào máy mở hoặc có cookie); không sửa được hồ sơ máy chủ, không bẻ được TLS.

TÀI SẢN CẦN BẢO VỆ

Phiên đã đăng nhập: Không để kẻ lạ dùng quyền hạn của chủ.

Trải nghiệm chủ thật: Không hỏi MFA quá nhiều, không thu hồi oan.

Hồ sơ nhịp gõ: Tránh bị chèn dữ liệu xấu làm sai lệch nhận dạng.

Riêng tư người dùng: Không lưu ký tự, chỉ ghi nhận thời điểm.

KỊCH BẢN TẤN CÔNG

A1	Người lạ dùng máy đang mở, gõ theo thói quen của mình.	Đã đo
A2	Biết nội dung cần gõ, nhưng không biết nhịp gõ của chủ.	Chưa đo
A3	Luyện bắt chước nhịp gõ của chủ thật.	Chưa đo
A4	Ghi lại gói dữ liệu nhịp gõ rồi gửi phát lại (replay).	Chưa đo

N = phím đầu tiên của người lạ. **TTD (Time To Detection, thời gian đến lúc phát hiện)** luôn tính từ N.

Câu hỏi nghiên cứu

Câu hỏi nghiên cứu

Kết quả bước đầu, chưa kết luận

Phát hiện sớm người lạ đang dùng phiên, mà không làm phiền chủ thật?

CÂU HỎI	GIẢ THUYẾT	KẾT QUẢ BƯỚC ĐẦU
RQ1 Ngưỡng riêng từng người	Ngưỡng riêng giúp chủ thật ít bị hỏi MFA hơn.	**Chưa kết luận** L1 và IF cho chiều ngược nhau.
RQ2 Cộng dồn bằng chứng	Cộng dồn bắt kẻ lạ tốt hơn xét từng đoạn riêng.	**Gợi ý ban đầu** Phát hiện tăng 0,36 → 0,63 (IF), nhưng chưa ghép cùng mức MFA.
RQ3 Cập nhật sau MFA	Cập nhật hồ sơ sau MFA giảm từ chối nhầm.	**Chưa thực hiện** P2 chưa triển khai.

Câu hỏi nghiên cứu

Kết quả bước đầu, chưa kết luận

Phát hiện sớm người lạ đang dùng phiên, mà không làm phiền chủ thật?

CÂU HỎI	GIẢ THUYẾT	KẾT QUẢ BƯỚC ĐẦU
RQ1 Ngưỡng riêng từng người	Ngưỡng riêng giúp chủ thật ít bị hỏi MFA hơn.	**Chưa kết luận** L1 và IF cho chiều ngược nhau.
RQ2 Cộng dồn bằng chứng	Cộng dồn bắt kẻ lạ tốt hơn xét từng đoạn riêng.	**Gợi ý ban đầu** Phát hiện tăng 0,36 → 0,63 (IF), nhưng chưa ghép cùng mức MFA.
RQ3 Cập nhật sau MFA	Cập nhật hồ sơ sau MFA giảm từ chối nhầm.	**Chưa thực hiện** P2 chưa triển khai.

Câu hỏi nghiên cứu

Kết quả bước đầu, chưa kết luận

Phát hiện sớm người lạ đang dùng phiên, mà không làm phiền chủ thật?

CÂU HỎI	GIẢ THUYẾT	KẾT QUẢ BƯỚC ĐẦU
RQ1 Ngưỡng riêng từng người	Ngưỡng riêng giúp chủ thật ít bị hỏi MFA hơn.	**Chưa kết luận** L1 và IF cho chiều ngược nhau.
RQ2 Cộng dồn bằng chứng	Cộng dồn bắt kẻ lạ tốt hơn xét từng đoạn riêng.	**Gợi ý ban đầu** Phát hiện tăng 0,36 → 0,63 (IF), nhưng chưa ghép cùng mức MFA.
RQ3 Cập nhật sau MFA	Cập nhật hồ sơ sau MFA giảm từ chối nhầm.	**Chưa thực hiện** P2 chưa triển khai.

02

Phương pháp và kiến trúc

Kiến trúc hệ thống

Kiến trúc hệ thống

Phần đã hiện thực và phần đề xuất

1
Thu phím
Chỉ thời điểm nhấn/nhả, **không lưu ký tự**

2
Cắt cửa sổ
Cửa sổ 50 phím, trích xuất 12 đặc trưng

3
Chấm điểm lạ
So với chủ thật (L1 hoặc IF)

4
Cộng dồn
CUSUM với hệ số suy giảm λ

5
Quyết định
Tiếp tục phiên, hỏi MFA, thu hồi

Lớp truyền & kiểm tra gói: Đề xuất chống phát lại (TLS, seq/nonce) – *thiết kế mục tiêu, chưa hiện thực trong pipeline mô phỏng*

Đã hiện thực

Collector • 12 đặc trưng • 2 bộ chấm điểm • 4 cấu hình (B0, B1, P1, B1 λ=1) • bộ đối chiếu

Kiến trúc hệ thống

Phần đã hiện thực và phần đề xuất

1
Thu phím
Chỉ thời điểm nhấn/nhả, **không lưu ký tự**

2
Cắt cửa sổ
Cửa sổ 50 phím, trích xuất 12 đặc trưng

3
Chấm điểm lạ
So với chủ thật (L1 hoặc IF)

4
Cộng dồn
CUSUM với hệ số suy giảm λ

5
Quyết định
Tiếp tục phiên, hỏi MFA, thu hồi

Lớp truyền & kiểm tra gói: Đề xuất chống phát lại (TLS, seq/nonce) – *thiết kế mục tiêu, chưa hiện thực trong pipeline mô phỏng*

Đã hiện thực

Collector • 12 đặc trưng • 2 bộ chấm điểm • 4 cấu hình (B0, B1, P1, B1 λ=1) • bộ đối chiếu

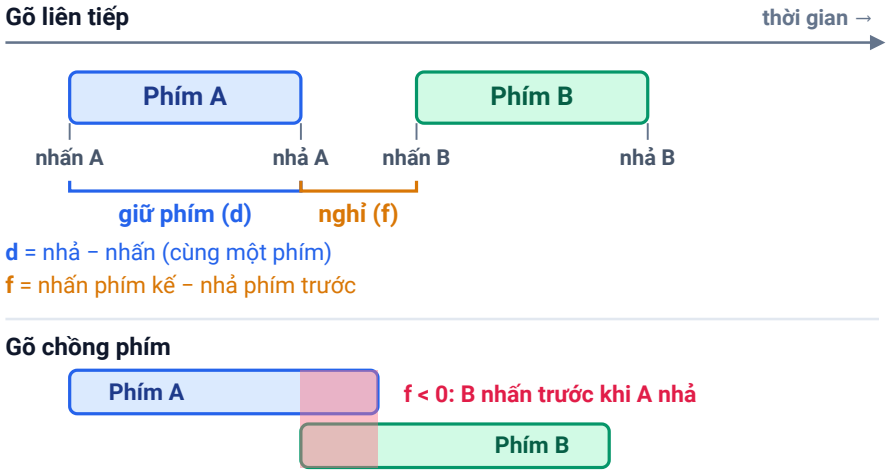
Chưa hiện thực

Lớp truyền chống phát lại • MFA thời gian thực • live end-to-end • cập nhật sau MFA (P2)

Đặc trưng nhịp gõ

Đặc trưng nhịp gõ

Thời gian giữ phím và khoảng nghỉ



Mỗi cửa sổ 50 phím → **12 đặc trưng** (giữ phím, khoảng nghỉ, tốc độ, sửa lỗi, độ biến động)

Chuẩn hóa theo từng người (median, MAD)

Không ghi ký tự: chỉ nhóm phím và thời điểm

Cộng dồn bằng chứng (CUSUM)

Cộng dồn bằng chứng (CUSUM)

Cửa sổ
50 phím

→

Điểm lạ a_t
L1 hoặc IF

→

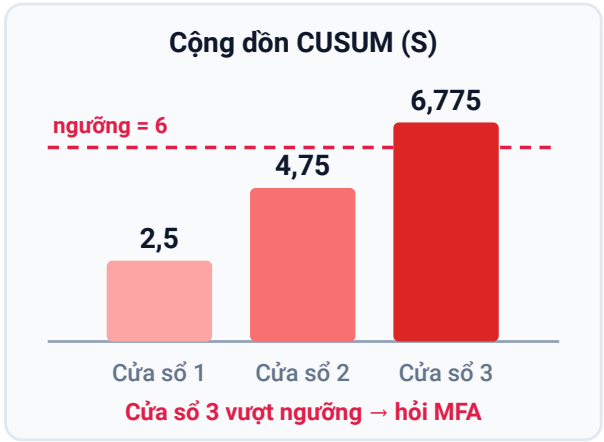
Chuẩn hóa z_t
$z_t = (a_t - \text{median}) / (1{,}4826 \cdot \text{MAD})$

→

Cộng dồn S_t
$S_t = \max\{0, \lambda \cdot S_{t-1} + z_t - k\}$

MAD (Median Absolute Deviation, độ lệch tuyệt đối trung vị); CUSUM (Cumulative Sum, tổng tích lũy).



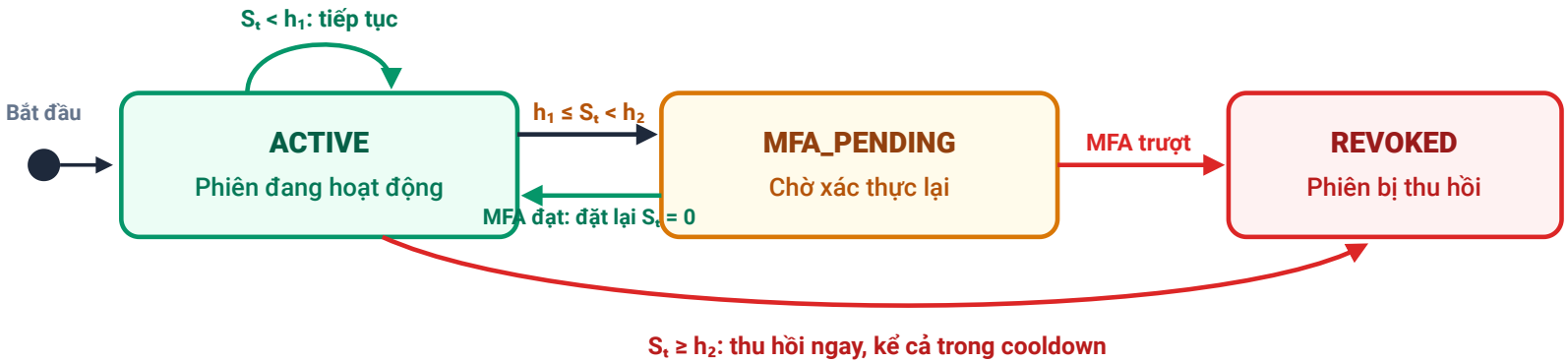


** Ví dụ minh họa (λ = 0,9; k = 0,5; ngưỡng 6), không phải kết quả thực nghiệm.*

Bộ điều khiển phiên

Bộ điều khiển phiên

Trạng thái phiên và bốn cấu hình so sánh



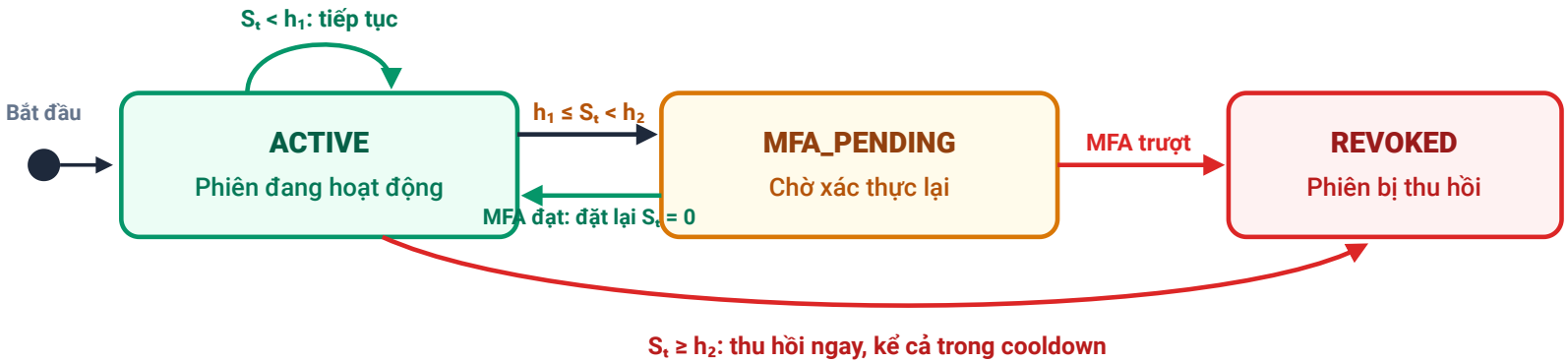
B0

Xét riêng từng cửa sổ, ngưỡng chung.

Tham số chọn trên **validation**; test chỉ chấm sau khi khóa cấu hình.

Bộ điều khiển phiên

Trạng thái phiên và bốn cấu hình so sánh



B0

Xét riêng từng cửa sổ, ngưỡng chung.

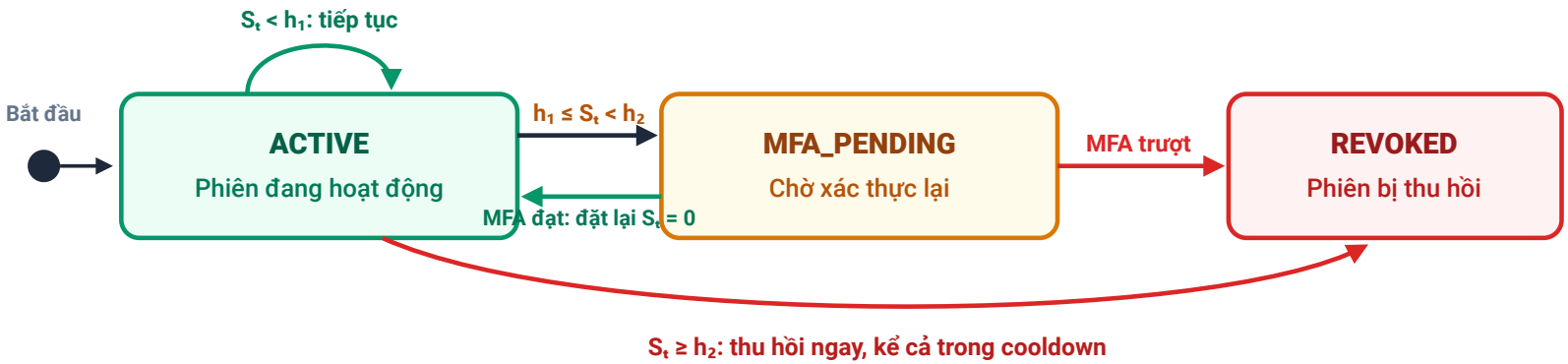
B1

Cộng dồn CUSUM, ngưỡng chung.

Tham số chọn trên **validation**; test chỉ chấm sau khi khóa cấu hình.

Bộ điều khiển phiên

Trạng thái phiên và bốn cấu hình so sánh



B0

Xét riêng từng cửa sổ, ngưỡng chung.

B1

Cộng dồn CUSUM, ngưỡng chung.

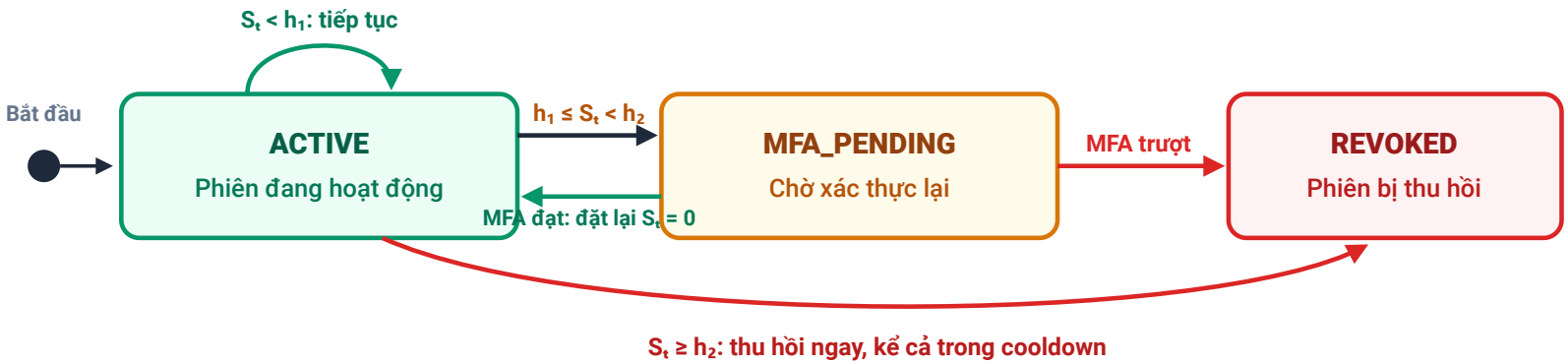
P1

Cộng dồn CUSUM, **ngưỡng riêng**.

Tham số chọn trên **validation**; test chỉ chấm sau khi khóa cấu hình.

Bộ điều khiển phiên

Trạng thái phiên và bốn cấu hình so sánh



B0

Xét riêng từng cửa sổ, ngưỡng chung.

B1

Cộng dồn CUSUM, ngưỡng chung.

P1

Cộng dồn CUSUM, **ngưỡng riêng**.

P2

P1 + cập nhật sau MFA. **(Chưa hiện thực)**

Tham số chọn trên **validation**; test chỉ chấm sau khi khóa cấu hình.

Nguồn công thức và tham số

Nguồn công thức và tham số

Thành phần	Nguồn tham khảo	Nhóm tự đề xuất / thiết kế
Median/MAD (hệ số 1,4826)	R Core Team [12]	Quy tắc chia tập, kỹ thuật xử lý khi MAD = 0
CUSUM (λ = 1)	NIST/SEMATECH [7]	**Hệ số quên λ < 1 (làm bằng chứng cũ phai dần)**
Isolation Forest	Liu, Ting, Zhou 2008 [8]	Hiện thực độc lập theo đặc tả, cấu hình 100 cây
Baseline L1	Killourhy & Maxion 2009 [4]	Quy trình baseline do nhóm tự hiện thực
Bộ điều khiển hai ngưỡng	Kiyani 2020 [6] (ý tưởng 2 ngưỡng)	**$h_2 = 2h_1$, cooldown 2 cửa sổ sau MFA**

CHỌN TRÊN VALIDATION: $\lambda \in \{0{,}9; 1\} \cdot k \in \{0{,}25; 0{,}5; 1\} \cdot h_1 \in \{0{,}5 \dots 12\}$

HẰNG SỐ THIẾT KẾ: W = 50 • IF 100 cây • $h_2 = 2h_1$ • cooldown 2 cửa sổ • L = 150 • A1 = 225 + 300 phím

03

Thực nghiệm và kết quả

Dữ liệu và quy trình

Dữ liệu và quy trình

Dữ liệu mô phỏng và phân chia thực nghiệm

DỮ LIỆU MÔ PHỎNG

4	28.800	432
hồ sơ nhịp gõ	lần gõ (24 phiên)	kịch bản / cấu hình

CHIA DỮ LIỆU THEO NGÀY

Ngày 1 — Huấn luyện (Train)

Ngày 2 — Validation (chỉnh điểm & ngưỡng)

Ngày 3 — Kiểm thử (Test khóa)

Dữ liệu và quy trình

Dữ liệu mô phỏng và phân chia thực nghiệm

DỮ LIỆU MÔ PHỎNG

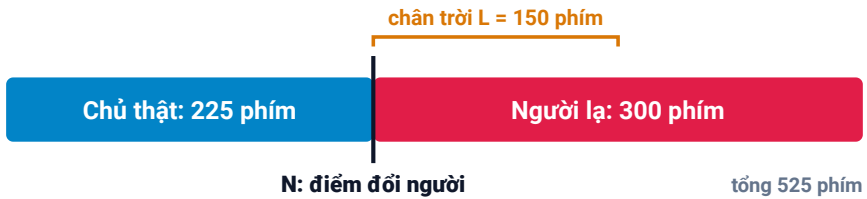
4	28.800	432
hồ sơ nhịp gõ	lần gõ (24 phiên)	kịch bản / cấu hình

CHIA DỮ LIỆU THEO NGÀY

Ngày 1 — Huấn luyện (Train)

Ngày 2 — Validation (chỉnh điểm & ngưỡng)

Ngày 3 — Kiểm thử (Test khóa)



** Mô hình không biết N; N chỉ dùng để chấm kết quả.*

Chỉ số đánh giá

Chỉ số đánh giá

Bắt người lạ, không làm phiền chủ thật

Bắt người lạ (An ninh)

- **Tỷ lệ phát hiện:** tỷ lệ kịch bản có cảnh báo sau N.
- **Median TTD:** số phím từ N đến khi phát hiện.
- **Trong 150 phím:** tỷ lệ phát hiện trong chân trời (L = 150).

Không làm phiền chủ thật (Khả dụng)

- **MFA/giờ:** tần suất hỏi xác thực lại trên phiên chủ thật.
- **Thu hồi oan:** số lần hệ thống đóng phiên nhầm của chủ.

Lưu ý về mẫu số

Đề tài luôn **báo cả hai cách tính** để đảm bảo tính khách quan và minh bạch.

IF, P1:
0,755 (bỏ 72 ca) → **0,613** **(đủ 432)**

** FAR (False Acceptance Rate), FRR (False Rejection Rate), EER (Equal Error Rate): chỉ số chẩn đoán ở mức cửa sổ.*

Chỉ số đánh giá

Bắt người lạ, không làm phiền chủ thật

Bắt người lạ (An ninh)

- **Tỷ lệ phát hiện:** tỷ lệ kịch bản có cảnh báo sau N.
- **Median TTD:** số phím từ N đến khi phát hiện.
- **Trong 150 phím:** tỷ lệ phát hiện trong chân trời (L = 150).

Không làm phiền chủ thật (Khả dụng)

- **MFA/giờ:** tần suất hỏi xác thực lại trên phiên chủ thật.
- **Thu hồi oan:** số lần hệ thống đóng phiên nhầm của chủ.

Lưu ý về mẫu số

Đề tài luôn **báo cả hai cách tính** để đảm bảo tính khách quan và minh bạch.

IF, P1:
0,755 (bỏ 72 ca) → **0,613** **(đủ 432)**

RÀNG BUỘC ĐẠT (ĐẶT TRƯỚC)

Phát hiện ≥ 80%	Median TTD ≤ 150 phím	Chưa cảnh báo tại 150 phím ≤ 15%	Không thu hồi oan (0 ca)

** FAR (False Acceptance Rate), FRR (False Rejection Rate), EER (Equal Error Rate): chỉ số chẩn đoán ở mức cửa sổ.*

Kết quả chẩn đoán

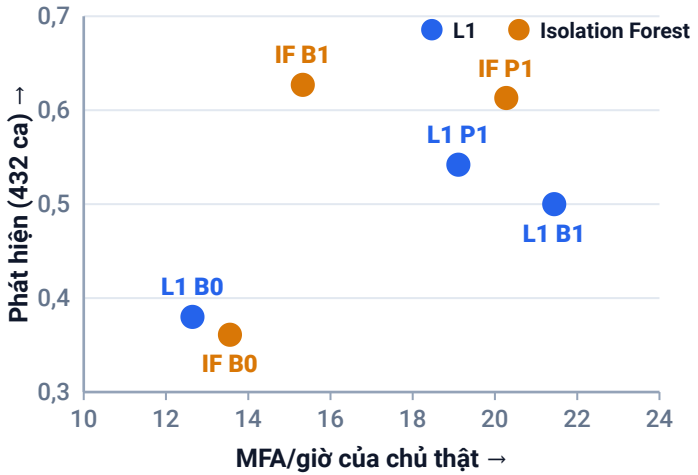
Kết quả chẩn đoán

Tập test, dữ liệu mô phỏng

Cấu hình	Phát hiện (432 ca)	Trong 150 phím	Median TTD	MFA /giờ	Thu hồi trước N	Thu hồi oan
L1, B0	0,380	0,197	181,25	12,6	0	1
L1, B1	0,500	0,361	150	21,4	54	2
L1, P1	0,542	0,330	150	19,1	18	2
IF, B0	0,361	0,137	162,5	13,6	0	0
IF, B1	0,627	0,345	162,5	15,3	0	1
IF, P1	0,613	0,519	137,5	20,3	72	4

* Trung bình 4 hồ sơ mô phỏng (432 ca / cấu hình)

L1: Baseline • IF: Isolation Forest



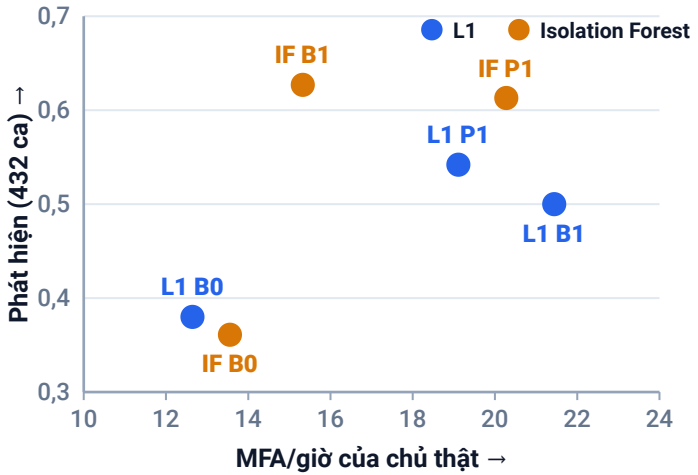
Kết quả chẩn đoán

Tập test, dữ liệu mô phỏng

Cấu hình	Phát hiện (432 ca)	Trong 150 phím	Median TTD	MFA /giờ	Thu hồi trước N	Thu hồi oan
L1, B0	0,380	0,197	181,25	12,6	0	1
L1, B1	0,500	0,361	150	21,4	54	2
L1, P1	0,542	0,330	150	19,1	18	2
IF, B0	0,361	0,137	162,5	13,6	0	0
IF, B1	0,627	0,345	162,5	15,3	0	1
IF, P1	0,613	0,519	137,5	20,3	72	4

* Trung bình 4 hồ sơ mô phỏng (432 ca / cấu hình)

L1: Baseline • IF: Isolation Forest



Cộng dồn tăng phát hiện nhưng MFA/giờ cũng tăng.

0/4 hồ sơ đạt ràng buộc → chưa kết luận.

04

Demo

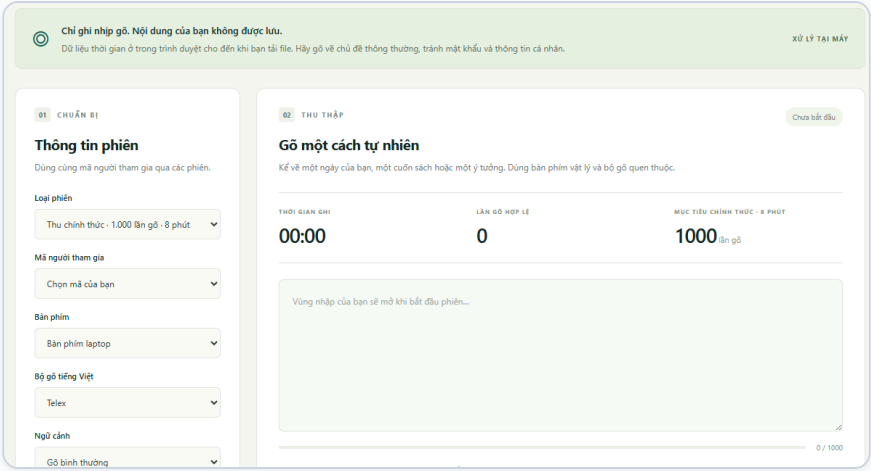
Demo 1 - Thu thập nhịp gõ

Demo 1 - Thu thập nhịp gõ

1 Thu thập — 2 Phát lại — 3 Đối chiếu

KỊCH BẢN THAO TÁC

1. Mở collector, chọn chế độ **Pilot**, xác nhận đồng thuận.
2. Gõ một đoạn ngắn, thử sửa bằng Backspace, thử dán văn bản (Paste).
3. Nhấp ra ngoài vùng gõ rồi chọn **Tiếp tục gõ**.
4. Kết thúc phiên và tải về file JSON.



Chỉ lưu loại phím và thời điểm

Không lưu ký tự

Chặn dán, ngắt đoạn khi mất tiêu điểm

Demo 2 - Phát lại kịch bản tiếp quản

Demo 2 - Phát lại kịch bản tiếp quản

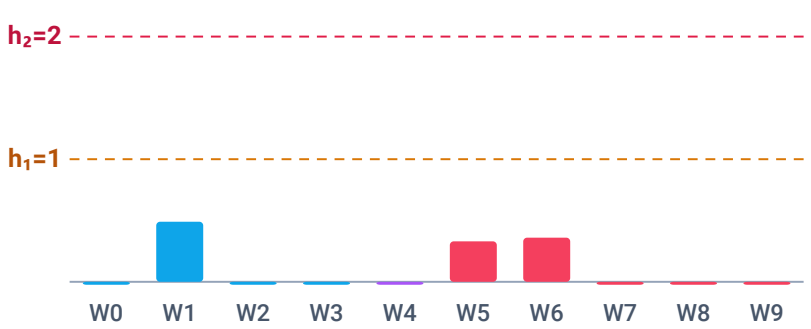
1 Thu thập | 2 Phát lại | 3 Đối chiếu

Cấu hình: Isolation Forest, SIM01, hai kịch bản A1 đầu tiên theo thứ tự trong file log

Chủ thật | Cửa sổ trộn | Người lạ

Ca 1: Ghép SIM02 (G0)

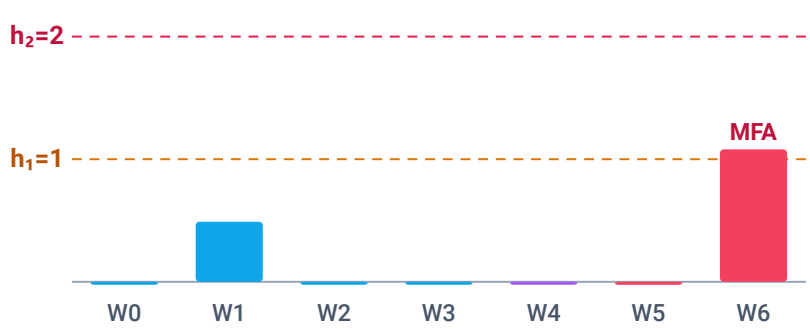
Bỏ sót cả 2 chính sách



Hết 275 phím vẫn chưa vượt h_1.

Ca 2: Ghép SIM02 (G1)

P1 bắt ở 125 phím



W6 vượt h_1 → hỏi MFA → người lạ trượt.

Demo 2 - Phát lại kịch bản tiếp quản

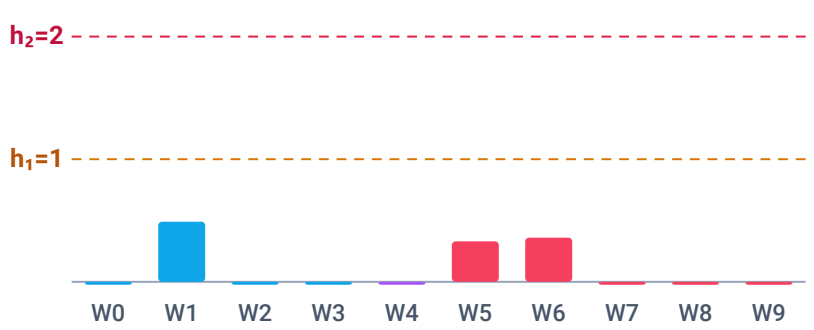
1 Thu thập | 2 Phát lại | 3 Đối chiếu

Cấu hình: Isolation Forest, SIM01, hai kịch bản A1 đầu tiên theo thứ tự trong file log

Chủ thật | Cửa sổ trộn | Người lạ

Ca 1: Ghép SIM02 (G0)

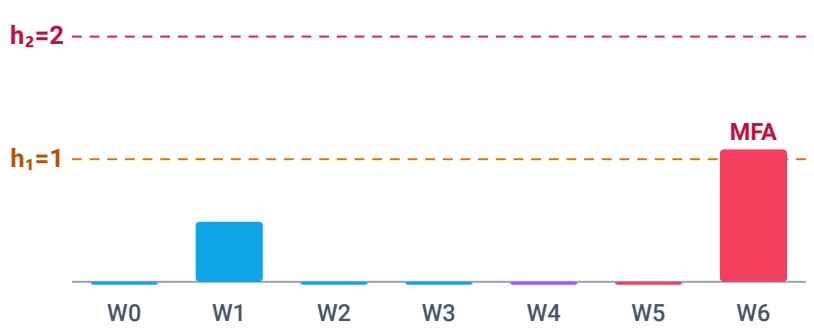
Bỏ sót cả 2 chính sách



Hết 275 phím vẫn chưa vượt h_1.

Ca 2: Ghép SIM02 (G1)

P1 bắt ở 125 phím



W6 vượt h_1 → hỏi MFA → người lạ trượt.

Đánh giá: Ca 1: B1 và P1 đều bỏ sót. Ca 2: ngưỡng riêng (P1) phát hiện ở 125 phím, ngưỡng chung (B1) ở 225 phím, muộn hơn chân trời 150.

Demo 3 - Đối chiếu kết quả

Demo 3 - Đối chiếu kết quả

1 Thu thập | 2 Phát lại | 3 Đối chiếu

KẾT QUẢ ĐỐI CHIẾU ĐỘC LẬP (RECONCILIATION LOG) exit: 0

```
// Kiểm tra 6 nhóm toàn vẹn dữ liệu:
"issue_counts": {
  "step": 0,      "events": 0,
  "outcome": 0,   "exposure": 0,
  "user": 0,      "macro": 0
}
```

✓ Tất cả 6/6 bài kiểm tra khớp 100% (Zero discrepancies)

Bộ đối chiếu độc lập:

Được viết riêng bởi thành viên khác trong nhóm, chạy kiểm toán độc lập trên toàn bộ log sinh ra từ mô hình.

Khớp hoàn toàn 0 sai lệch:

Mọi sự kiện phân loại, chuyển trạng thái và tính toán độ phơi nhiễm đều được thẩm tra chéo khớp tuyệt đối.

29.183	7.600	3.520
Quyết định đối chiếu	Sự kiện MFA / Thu hồi	Kết cục phiên kiểm tra

Demo 3 - Đối chiếu kết quả

1 Thu thập 2 Phát lại 3 Đối chiếu

KẾT QUẢ ĐỐI CHIẾU ĐỘC LẬP (RECONCILIATION LOG) exit: 0

```
// Kiểm tra 6 nhóm toàn vẹn dữ liệu:
"issue_counts": {
  "step": 0,      "events": 0,
  "outcome": 0,   "exposure": 0,
  "user": 0,      "macro": 0
}
```

✓ Tất cả 6/6 bài kiểm tra khớp 100% (Zero discrepancies)

Bộ đối chiếu độc lập:

Được viết riêng bởi thành viên khác trong nhóm, chạy kiểm toán độc lập trên toàn bộ log sinh ra từ mô hình.

Khớp hoàn toàn 0 sai lệch:

Mọi sự kiện phân loại, chuyển trạng thái và tính toán độ phơi nhiễm đều được thẩm tra chéo khớp tuyệt đối.

Chỉ số chẩn đoán mức cửa sổ (FAR, FRR, EER) khớp toàn bộ **8/8 cặp** kịch bản thử nghiệm.

29.183	7.600	3.520
Quyết định đối chiếu	Sự kiện MFA / Thu hồi	Kết cục phiên kiểm tra

05

Giới hạn và kết luận

Giới hạn nghiên cứu

Giới hạn nghiên cứu

Dữ liệu mô phỏng

Cho thấy quy trình phân tích chạy đúng và chặt chẽ, nhưng chưa phản ánh đầy đủ độ biến động trên người dùng thật.

Mới đo một kiểu tấn công (A1)

Kẻ tấn công được ghép offline từ phiên người khác; cơ chế kiểm tra chống phát lại mới ở mức thiết kế.

Giới hạn nghiên cứu

Dữ liệu mô phỏng

Cho thấy quy trình phân tích chạy đúng và chặt chẽ, nhưng chưa phản ánh đầy đủ độ biến động trên người dùng thật.

Mới đo một kiểu tấn công (A1)

Kẻ tấn công được ghép offline từ phiên người khác; cơ chế kiểm tra chống phát lại mới ở mức thiết kế.

MFA chưa phải hệ thống thật

Giả định lý tưởng: chủ tài khoản luôn vượt qua MFA thành công, kẻ lạ luôn xác thực thất bại.

So sánh chưa hoàn toàn cân bằng

Các cấu hình hỏi MFA với tần suất khác nhau nên chưa so được ở cùng mức đánh đổi, kết luận dừng ở bước đầu.

Giới hạn nghiên cứu

Dữ liệu mô phỏng

Cho thấy quy trình phân tích chạy đúng và chặt chẽ, nhưng chưa phản ánh đầy đủ độ biến động trên người dùng thật.

Mới đo một kiểu tấn công (A1)

Kẻ tấn công được ghép offline từ phiên người khác; cơ chế kiểm tra chống phát lại mới ở mức thiết kế.

MFA chưa phải hệ thống thật

Giả định lý tưởng: chủ tài khoản luôn vượt qua MFA thành công, kẻ lạ luôn xác thực thất bại.

So sánh chưa hoàn toàn cân bằng

Các cấu hình hỏi MFA với tần suất khác nhau nên chưa so được ở cùng mức đánh đổi, kết luận dừng ở bước đầu.

CHƯA HIỆN THỰC (GIỚI HẠN PHẠM VI)

- Hệ thống live end-to-end
- Chống phát lại trên mạng
- Cập nhật hồ sơ sau MFA (P2)
- Thuật toán One-Class SVM

Kết luận và hướng phát triển

Kết luận và hướng phát triển

ĐIỀU RÚT RA

1. Khoảng hở sau MFA là có thật

Nhịp gõ là tín hiệu bổ sung thụ động, không làm gián đoạn trải nghiệm người dùng.

2. Trong mô phỏng, cộng dồn tăng phát hiện

Nhưng kèm nhiều lần hỏi MFA hơn: một đánh đổi tất yếu, chưa phải kết luận tối ưu.

Kết luận và hướng phát triển

ĐIỀU RÚT RA

1. Khoảng hở sau MFA là có thật

Nhịp gõ là tín hiệu bổ sung thụ động, không làm gián đoạn trải nghiệm người dùng.

2. Trong mô phỏng, cộng dồn tăng phát hiện

Nhưng kèm nhiều lần hỏi MFA hơn: một đánh đổi tất yếu, chưa phải kết luận tối ưu.

3. Đóng góp chính là quy trình đánh giá

Kiểm lại được độc lập (TTD, MFA/giờ, đối chiếu), sẵn sàng chạy trên dữ liệu thật.

Kết luận và hướng phát triển

ĐIỀU RÚT RA

1. Khoảng hở sau MFA là có thật

Nhịp gõ là tín hiệu bổ sung thụ động, không làm gián đoạn trải nghiệm người dùng.

2. Trong mô phỏng, cộng dồn tăng phát hiện

Nhưng kèm nhiều lần hỏi MFA hơn: một đánh đổi tất yếu, chưa phải kết luận tối ưu.

3. Đóng góp chính là quy trình đánh giá

Kiểm lại được độc lập (TTD, MFA/giờ, đối chiếu), sẵn sàng chạy trên dữ liệu thật.

→ BƯỚC TIẾP THEO

1. **Thu dữ liệu thật**
   20 người × 5 phiên (2 train, 2 validation, 1 test) bằng công cụ collector đã kiểm thử.
2. **Gắn hệ thống live**
   Ghép collector với bộ điều khiển phiên, bổ sung lớp truyền chống phát lại.
3. **Triển khai P2**
   Tự cập nhật hồ sơ sau MFA, thử nghiệm thêm đặc trưng và tinh chỉnh ngưỡng tối ưu.

Tài liệu tham khảo

Tài liệu tham khảo

Tài liệu tham khảo

[1] NIST (2025) NIST SP
SP 800-63B-4: Digital Identity Guidelines - Session Management

[2] OWASP (2024) Guideline
Session Management Cheat Sheet

[3] Dhakal et al. (2018) ACM CHI
Observations on typing from 136 million keystrokes

[4] Killourhy & Maxion (2009) IEEE DSN
Comparing anomaly-detection algorithms for keystroke dynamics

[5] Bours (2012) IST-Report
Continuous keystroke dynamics: A different perspective towards biometric evaluation

[6] Kiyani et al. (2020) IEEE Access
Continuous user authentication featuring keystroke dynamics based on RCM

[7] NIST/SEMATECH Handbook
e-Handbook of Statistical Methods, Mục 6.3.2.3: CUSUM Control Charts

[8] Liu, Ting, Zhou (2008) IEEE ICDM
Isolation forest: Anomaly detection with isolation

[9] Acien et al. (2021) IEEE TBIOM
TypeNet: Deep Learning Keystroke Biometrics

[10] Stragapede et al. (2024, 2025) NCA / PR
TypeFormer (Transformers) & KVC-onGoing Challenge (> 185k users)

[11] TypingDNA (2024) Industry
ActiveLock: Continuous endpoint identity authentication

[12] R Core Team Documentation
`mad` : Median Absolute Deviation (hệ số hiệu chỉnh phân phối chuẩn 1,4826)

Xin cảm ơn thầy cô và các bạn đã lắng nghe.

Mã nguồn và bộ dữ liệu mô phỏng: https://github.com/zgid123/master-aissec-seminar.git